

Informe STRIDE.

El marco STRIDE, nacido como humilde checklist de Microsoft, se ha convertido —casi sin pretenderlo— en una gramática para describir cómo se rompe el mundo digital: suplantando, manipulando, negando, filtrando, agotando y escalando privilegios.¹²³

1. De STRIDE como “lista de la compra” a STRIDE como sistema de indicadores

Desde 2025 se observa un desplazamiento claro: STRIDE ya no se usa solo para enumerar amenazas, sino como esqueleto para construir indicadores cuantitativos y cualitativos de riesgo, alineados con marcos normativos (NIS2, ISO/IEC 42001, ISO/SAE 21434) y con métricas de impacto en negocio.⁴⁵

En trabajos recientes sobre sanidad digital e IoT sanitario, STRIDE se integra con DREAD, CVSS y métricas de seguridad funcional para convertir cada categoría (S, T, R, I, D, E) en conjuntos de “preguntas medibles”: número de flujos autenticados, proporción de registros firmados, porcentaje de datos cifrados, tiempo medio de indisponibilidad, etc. En el sector financiero, se han utilizado tablas STRIDE (S–E) con códigos de amenaza (S1, T1, R1...) para registrar tanto escenarios reales (casos de fraude interno) como los controles implantados, convirtiendo cada celda en una unidad medible de exposición residual.⁶⁷⁸

En paralelo, guías nacionales (como la del NCSC británico para ciudades conectadas) formalizan STRIDE como metodología iterativa con talleres estructurados, resultados repetibles y trazables y, sobre todo, orientada a que cada amenaza termine asociada a un “estado”: identificado, mitigado, aceptado, transferido, con indicadores de madurez en cada fase.⁹¹⁰

1 <https://www.practical-devsecops.com/what-is-stride-threat-model/>

2 <https://www.softwaresecured.com/post/stride-threat-modelling>

3 https://en.wikipedia.org/wiki/STRIDE_model

4 <https://blog.rsisecurity.com/stride-framework-threat-modeling-iso-42001/>

5 <https://www.sciencedirect.com/science/article/abs/pii/S0167404823003012>

6 <https://www.softwaresecured.com/post/stride-threat-modelling>

7 <https://www.sciencedirect.com/science/article/abs/pii/S0167404823003012>

8 <https://www.practical-devsecops.com/what-is-stride-threat-model/>

9 <https://www.gov.uk/government/publications/secure-connected-places-playbook-documents/conducting-a-stride-based-threat-analysis>

10 <https://www.ncsc.gov.uk/collection/risk-management/threat-modelling>

2. Tendencias recientes por categoría STRIDE: de la vulnerabilidad puntual al indicador sistémico

Spoofing (Suplantación)

La suplantación ha dejado de ser “la cosa del phishing” para convertirse en una métrica transversal de identidad digital y de gobierno de credenciales.

En sanidad digital de pequeña escala (clínicas, servicios de telemedicina), se mide ya: proporción de accesos críticos protegidos por MFA, número de integraciones API externas con autenticación fuerte, volumen de intentos de acceso con credenciales robadas o tokens reutilizados, y existencia de controles específicos sobre APIs de IA (p. ej. suplantación de clientes que llaman a modelos NLP o de OCR clínico). En análisis financieros de amenazas internas se etiqueta explícitamente la suplantación de clientes o empleados como escenario S1/S2 y se asocia a métricas de uso de MFA, biometría y anomalías de login (ubicaciones, horarios, dispositivos).¹¹¹²

En guías nacionales de threat modeling, la métrica empieza a ser menos “¿tenemos autenticación?” y más “¿en cuántos flujos de datos y sistemas críticos el spoofing sigue siendo plausible?”. Se trabaja con indicadores como:

- Porcentaje de interfaces externas sin autenticación mutua o sin MFA.
- Número de identidades con credenciales compartidas o cuentas genéricas.
- Tasa de incidentes de suplantación por millón de transacciones o usuarios.⁷⁶

Para un uso nacional-territorial, estos indicadores pueden agregarse por sector (banca, energía, transporte) cruzando datos de CERT nacionales y de informes de incidentes, igual que se hace hoy con estadísticas de incidentes por tipo sin llegar a subtipo STRIDE.¹³¹⁴

Tampering (Manipulación)

La manipulación de datos ya no se persigue solo con firewalls: se mide a través de:

- Porcentaje de logs y datos críticos con protección criptográfica (sellos de tiempo, hashes encadenados, almacenes inmutables).²
- Número de sistemas donde el personal interno puede modificar directamente registros sin trazabilidad robusta.
- Proporción de dispositivos IoT con firmware firmado, arranque seguro y canales cifrados aún expuestos a manipulación (p. ej. sensores médicos, equipamiento conectado).¹

¹¹ <https://www.practical-devsecops.com/what-is-stride-threat-model/>

¹² <https://www.softwaresecured.com/post/stride-threat-modelling>

¹³ <http://espanadigital.gob.es/en/actualidad/incibe-gestiono-122223-incidentes-de-ciberseguridad-en-2025-un-26-mas-que-el-ano>

¹⁴ <https://ncsi.ega.ee/country/es/>

En evaluaciones recientes de dispositivos IoT sanitarios usando STRIDE + DREAD, se puntúa el impacto del tampering según efectos en seguridad de pacientes, continuidad de servicio y privacidad, con métricas diferenciadas de impacto de seguridad física, financiera, operativa, de privacidad y regulatoria. En banca, las tablas de tampering (T1–T5) incluyen manipulación de transacciones, de logs, de scripts de procesamiento automatizado y de validaciones de entrada, con controles asociados (cifrado, RBAC, logs inmutables, revisiones de código) que pueden traducirse en métricas de cobertura (“porcentaje de procesos críticos con doble control, porcentaje de scripts sujetos a revisión, número de alertas de integridad disparadas por mes”).¹⁵¹⁶¹⁷

Repudiación

La vieja categoría más abstracta de STRIDE se ha vuelto muy concreta gracias a los requerimientos normativos de trazabilidad y no repudio.

En entornos clínicos, la incapacidad de atribuir acciones a usuarios concretos en flujos generados por IA (notas, órdenes, modificaciones de registros) se identifica explícitamente como amenaza de repudiación, y se propone medir: porcentaje de acciones generadas por IA con registro explícito de origen (modelo, versión, usuario que valida), cobertura de logging de alta granularidad y tiempo medio para reconstruir un evento.¹⁸

En la banca, tablas específicas de repudiación (R1–R3) miden la existencia de logs detallados, de firmas digitales y de control de cambios en configuraciones de interfaces y sistemas, con recomendaciones de registros inmutables y logs externos que permiten indicadores como: porcentaje de sistemas bajo logging inmutable, número de eventos de seguridad sin logs suficientes para atribución, o capacidad de retención de logs en meses.¹⁹

A escala nacional, esto se conecta con obligaciones de registro de incidentes bajo NIS2 y con indicadores de capacidad de respuesta: número de incidentes en los que no se pudo determinar actor o vector por falta de trazabilidad, tiempos de investigación, etc.²⁰²¹

Information Disclosure (Divulgación de información)

Aquí la convergencia con métricas clásicas de privacidad y protección de datos es evidente, pero el prisma STRIDE obliga a detallar dónde y cómo se filtra.

En sanidad se han analizado flujos donde modelos de IA y APIs externas exponen datos sensibles a través de: almacenamiento en la nube mal configurado, tráfico API sin cifrado robusto, pipelines de

15 <https://www.sciencedirect.com/science/article/abs/pii/S0167404823003012>

16 <https://www.softwaresecured.com/post/stride-threat-modelling>

17 <https://www.practical-devsecops.com/what-is-stride-threat-model/>

18 <https://www.practical-devsecops.com/what-is-stride-threat-model/>

19 <https://www.softwaresecured.com/post/stride-threat-modelling>

20 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

21 <https://ncsi.ega.ee/country/es/>

OCR y NLP no controlados y salidas de modelos (incluidos LLM) que pueden revelar información tanto de entrenamiento como de prompts o sesiones. Esto produce métricas como: porcentaje de flujos donde los datos se cifran en tránsito y reposo, número de integraciones externas con evaluaciones de riesgo de proveedor, frecuencia de comprobación de fugas en salidas de modelos, o número de hallazgos de exposición de PHI/PII por año.²²

En banca, las tablas de información disclosure (I1–I4) consideran exposición tanto en bases de datos como en logs, herramientas de monitorización o interfaces web (p. ej. cachés inseguras), ligando controles (RBAC, cifrado, control estricto de accesos, deshabilitación de caché) a indicadores de superficie de exposición.²³

Para España, los datos incipientes de INCIBE sobre sistemas vulnerables relevantes (más de 237.000 en 2025) y los incidentes por sector (banca, transporte, energía...) podrían clasificarse con un esquema STRIDE, pasando de “incidente genérico” a “incidente de divulgación por vector X, sobre activo Y”, permitiendo métricas nacionales por tipo de divulgación y superficie afectada.²⁴

Denial of Service (DoS)

La denegación de servicio ha dejado de ser sinónimo de DDoS volumétrico y se integra en modelos de resiliencia operativa y continuidad.

En sistemas clínicos conectados, el DoS se modela tanto en el nivel técnico (caída de APIs, interrupciones de red, saturación de servicios de IA) como en el nivel operativo (imposibilidad de acceder a historiales, fallos de dispositivos IoT), con métricas como tiempo total de indisponibilidad anual, número de degradaciones de rendimiento y presencia de redundancia y planes de recuperación específicos.²⁵

En el sector financiero, los modelos STRIDE aplicados a insider threats incluyen escenarios de DoS sobre la propia monitorización de seguridad (D2) o sobre componentes web (D3), destacando que un empleado con privilegios puede degradar la capacidad de detección y generar una “cortina de humo” para fraude. Esto conduce a indicadores de robustez de la función de seguridad: redundancia de sistemas SOC, tiempo máximo tolerado de caída de herramientas de monitorización, número de eventos donde se degradó el logging o el SIEM.²⁶

A escala nacional, las nuevas políticas de ciberseguridad en España sitúan la continuidad de servicios esenciales en el centro de la agenda, recogiendo que en 2024 se detectaron más de 100.000 ciberataques y uno muy grave cada tres días, y reorientando inversiones hacia protección de infraestructuras críticas, ciberdefensa y resiliencia ante incidentes. Integrar STRIDE en estos

²² <https://www.practical-devsecops.com/what-is-stride-threat-model/>

²³ <https://www.softwaresecured.com/post/stride-threat-modelling>

²⁴ <http://espanadigital.gob.es/en/actualidad/incibe-gestiono-122223-incidentes-de-ciberseguridad-en-2025-un-26-mas-que-el-ano>

²⁵ <https://www.practical-devsecops.com/what-is-stride-threat-model/>

²⁶ <https://www.softwaresecured.com/post/stride-threat-modelling>

indicadores permitiría clasificar qué proporción de incidentes nacionales se corresponde realmente con DoS efectivos o intentos, frente a otros tipos, y evaluar la exposición por sector.²⁷

Elevation of Privilege (Escalada de privilegios)

La categoría favorita de los atacantes de siempre se ha sofisticado tanto que ahora sirve como proxy de la madurez de control de identidades y accesos.

En sanidad, se documentan escenarios donde configuraciones deficientes de RBAC o de tokens en aplicaciones de EHR permiten a usuarios elevarse a roles administrativos, acceder a datos masivos o modificar flujos de IA; los controles propuestos incluyen RBAC estricto, privilegios mínimos, MFA reforzada y revisiones periódicas de permisos, con métricas claras: número de cuentas con privilegios administrativos, frecuencia de revisión de permisos, número de hallazgos de escalada posible por auditoría.²⁸

En banca, las tablas de Elevation of Privilege (E1–E3) recogen desde el abuso directo de privilegios administrativos hasta la manipulación de herramientas de seguridad para desactivar alertas o elevarse en la propia infraestructura de monitorización, destacando la necesidad de segregar funciones, aplicar MFA “dentro del SOC” y auditar cambios en configuración de seguridad. Algunos informes técnicos sobre vulnerabilidades recientes en SQL Server y servicios de Windows muestran cómo una única escalada local puede derivar en un encadenamiento STRIDE completo (DoS, disclosure, spoofing, tampering) en sistemas críticos.²⁹³⁰³¹

A nivel país, la escalada de privilegios se traduce en métricas sobre gestión de identidades privilegiadas (PAM), adopción de Zero Trust y frecuencia de auditorías de cuentas con altos privilegios: datos que hoy se capturan indirectamente en índices de ciberseguridad nacionales — como el National Cyber Security Index— y que podrían mapearse explícitamente a la “E” de STRIDE en futuras revisiones.³²

²⁷ https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

²⁸ <https://www.practical-devsecops.com/what-is-stride-threat-model/>

²⁹ <https://zeropath.com/blog/windows-ssdp-cve-2025-47976-analysis>

³⁰ <https://specterops.io/blog/2026/01/15/mssql-and-sccm-elevation-of-privilege-vulnerabilities/>

³¹ <https://www.softwaresecured.com/post/stride-threat-modelling>

³² <https://ncsi.ega.ee/country/es/>

Tabla ilustrativa: ejemplos de indicadores STRIDE por categoría

Categoría STRIDE	Ejemplo de indicador organizativo	Posible agregación nacional (España)
Spoofing	% de accesos críticos con MFA 1	Número de incidentes de suplantación reportados por sector 8
Tampering	% de logs protegidos con integridad criptográfica 2	Nº de eventos de manipulación detectados en infraestructuras esenciales 8
Repudiación	% de sistemas con logs inmutables y firmas digitales 2	Nº de incidentes donde no se pudo atribuir acciones por falta de trazabilidad 10
Info. Disclosure	Nº de integraciones externas con evaluación de riesgo completada 1	Volumen de sistemas vulnerables con exposición de datos en operadores esenciales 8
DoS	Horas de indisponibilidad anual de sistemas críticos 1	Nº de incidentes muy graves asociados a pérdida de servicio esencial 11
Elev. Privilege	Nº de cuentas con privilegios administrativos y revisiones/año 2	Grado de implantación de PAM/Zero Trust en sectores NIS2 109

3. España, NIS2 y la tentación de medir STRIDE a escala país

España está en pleno rediseño de su arquitectura institucional de ciberseguridad con la transposición de NIS2 mediante la Ley de Coordinación y Gobernanza de la Ciberseguridad, la creación del Centro Nacional de Ciberseguridad bajo Interior y el refuerzo de INCIBE como brazo operativo para ciudadanos, empresas y operadores esenciales.³³³⁴³⁵

En 2024 se registraron más de 100.000 ciberataques, con uno muy grave cada tres días, y en 2025 INCIBE gestionó más de 122.000 incidentes y detectó más de 237.000 sistemas vulnerables relevantes, con especial impacto en banca, transporte, energía y otras infraestructuras reguladas por NIS2. Estas cifras, por sí solas, son la antítesis de STRIDE: agregan todo tipo de incidentes sin clasificar los modos de fallo. Precisamente ahí está la oportunidad: aprovechar el aumento de

33 <https://www.lamoncloa.gob.es/lang/en/presidente/news/paginas/2025/20251016-information-security-meeting.aspx>

34 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

35 https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

obligaciones de reporte bajo NIS2 para exigir que cada incidente nacional se clasifique no solo por sector y criticidad, sino también por categoría STRIDE.³⁶³⁷

La infraestructura está: índice nacional de ciberseguridad, estrategias nacionales y planes actualizados de ciberseguridad, organismos coordinadores y un volumen considerable de incidentes procesados anualmente. Lo que falta es la traducción explícita a métricas STRIDE: porcentajes de incidentes por categoría, superficie de exposición por tipo de amenaza, evolución anual por sector y madurez de mitigaciones asociadas (por ejemplo, cobertura de MFA para spoofing, logs inmutables para repudiation, cifrado fuerte y data minimization para info disclosure, redundancia y ejercicios de crisis para DoS, y PAM/Zero Trust para elevation of privilege).³⁸³⁹

En la práctica, esto se podría materializar en anexos técnicos del Esquema Nacional de Seguridad o en guías del CCN y de INCIBE, donde los actuales controles se mapearan formalmente a STRIDE y se definieran indicadores mínimos para cada ámbito. No sería una revolución conceptual, sino un ejercicio de contabilidad rigurosa: dejar de hablar de “ciberataques” en bloque y empezar a tratarlos como partidas contables de spoofing, tampering, etc., con sus respectivas cuentas de mitigación.⁴⁰⁴¹

4. Tendencias internacionales: STRIDE maridado con otros marcos y con la IA

A nivel internacional, los trabajos más recientes no se contentan con STRIDE “puro”, sino que lo encajan en arquitecturas más amplias:

36 https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

37 <http://espanadigital.gob.es/en/actualidad/incibe-gestiono-122223-incidentes-de-ciberseguridad-en-2025-un-26-mas-que-el-ano>

38 <https://ncsi.ega.ee/country/es/>

39 https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

40 <http://espanadigital.gob.es/en/actualidad/incibe-gestiono-122223-incidentes-de-ciberseguridad-en-2025-un-26-mas-que-el-ano>

41 <https://ncsi.ega.ee/country/es/>

- En automoción conectada, se utiliza STRIDE para clasificar amenazas dentro de marcos TARA alineados con ISO/SAE 21434, relacionando cada amenaza con métricas de daño en seguridad física, operativa, financiera y regulatoria.⁵
- En sanidad digital y IoT clínico, se combinan STRIDE y DREAD para cuantificar riesgo en dispositivos y servicios basados en IA, ponderando daño, explotabilidad, usuarios afectados y cumplimiento regulatorio, y derivando listas priorizadas de mitigaciones con impacto medible en la reducción de superficie de ataque.⁵¹
- En análisis de amenazas internas en banca, se integran STRIDE y modelos de criminología (triángulo del fraude) para vincular vulnerabilidades técnicas con motivaciones y presiones humanas, proponiendo controles y métricas tanto técnicas (número de logs inmutables, controles de acceso, anomalías detectadas) como de comportamiento (indicadores de presión, racionalización, oportunidades).²

La guinda viene de la mano de la IA: guías recientes para la gestión del riesgo de sistemas de IA alineados con ISO/IEC 42001 recomiendan STRIDE como herramienta para identificar amenazas sobre modelos y datos, enfatizando la necesidad de medir riesgos de spoofing de modelos o APIs, tampering de datos de entrenamiento, divulgación mediante inferencia de modelos y escaladas de privilegios en pipelines de ML. En paralelo, propuestas de “STRIDE sociales” para desinformación asistida por IA extienden el acrónimo a un plano de gobernanza, lo que, irónicamente, demuestra que el modelo ha trascendido su ámbito original aunque a costa de cierta sobrecarga semántica.⁴²⁴³⁴⁴

5. Hacia un informe STRIDE nacional para España

Si tomamos en serio la idea de un STRIDE “de país” aplicable a España, las tendencias recientes sugieren varios principios:

Primero, aceptar que STRIDE es un lenguaje, no un fin: su utilidad a nivel territorial surge cuando se le acopla un sistema métrico coherente con los marcos europeos (NIS2, DORA, CER, AI Act) y con índices globales donde España ya puntúa razonablemente bien. Segundo, exigir que los repositorios de incidentes (INCIBE-CERT, CCN-CERT, operadores esenciales) incluyan clasificación STRIDE mínima, de forma que cada incidente nacional alimenta series temporales por categoría, sector, criticidad, vector y controles afectados.⁴⁵⁴⁶⁴⁷

Tercero, mapear el Esquema Nacional de Seguridad y las nuevas obligaciones de NIS2 a las seis letras del acrónimo, de forma que por cada control se definan al menos uno o dos indicadores

⁴² <https://pmc.ncbi.nlm.nih.gov/articles/PMC9459912/>

⁴³ <https://www.acigjournal.com/pdf-213864-133112?filename=Social-Cybersecurity-as-D.pdf>

⁴⁴ <https://blog.rsisecurity.com/stride-framework-threat-modeling-iso-42001/>

⁴⁵ <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

⁴⁶ <https://ncsi.ega.ee/country/es/>

⁴⁷ <http://espanadigital.gob.es/en/actualidad/incibe-gestiona-122223-incidentes-de-ciberseguridad-en-2025-un-26-mas-que-el-ano>

mensurables: porcentaje de flujos autenticados (S), de datos y logs con integridad garantizada (T, R), de información sensible cifrada y correctamente segregada (I), de servicios críticos con redundancia y pruebas de continuidad (D), y de identidades privilegiadas gobernadas bajo principios Zero Trust (E).⁴⁸

Cuarto, no olvidar la dimensión humana: los trabajos sobre amenazas internas recuerdan que, sin indicadores de cultura organizativa, formación y presión sobre el personal, las mejores métricas de STRIDE seguirán siendo contabilidad forense de lo que ya ha ardido.⁵⁰

Y, finalmente, abrazar un poco de ironía ilustrada: el país que ha decidido llamar “cervezas” a sus CERTs (INCIBE, CCN, órganos sectoriales) podría permitirse un “Informe STRIDE España” anual donde, con rigor estadístico y cierto gusto por la literatura de catástrofes evitadas, se midieran las seis formas en que intentan tumbar nuestros sistemas... y las seis formas en que medimos que no lo consiguen.

171819202122232425262728

⁴⁸ <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

⁴⁹ <https://ncsi.ega.ee/country/es/>

⁵⁰ <https://www.softwaresecured.com/post/stride-threat-modelling>